

Production: Does the Empirical Literature Support the Marketing Claims?

Research 03

Report title	UEBA in Production: Does the Empirical Literature Support the Marketing Claims?
Due	17 May, 2026
Course	Incident Handling & Response — Research 03
Name	Mohammad Salem Hassani
Student ID	254880
Instructor	Asen Grozdanov

Contents

Abstract.....	1
1. Introduction.....	1
2. Literature Survey and Discussion	2
2.1 What the papers measured and how	2
2.2 Where the sources agree	2
2.3 Where the sources diverge — the dataset gap	3
2.4 The privacy dimension	3
3. Conclusion and Implications	4
References.....	5

Abstract

User and Entity Behaviour Analytics (UEBA) is marketed as the solution to insider-threat blind spots that signature-based tools cannot close. This report surveys three peer-reviewed empirical studies published between 2022 and 2025 and asks whether the performance figures they report translate to production environments. The literature reveals a consistent pattern: laboratory evaluations on the CERT r4.2 benchmark achieve high recall and precision-recall AUC scores above 0.70, yet every paper acknowledges a fundamental dataset-reality gap — CERT is synthetically labelled and structurally unlike live enterprise logs. This report argues that the empirical evidence partially supports UEBA's detection capability in controlled settings, but the marketing claim that UEBA reduces insider-threat risk in production remains unvalidated at scale. The gap matters for incident-response teams deciding how far to trust a UEBA score during a live investigation.

1. Introduction

Insider threats — defined as harmful acts by individuals with legitimate access to organisational systems — are among the most costly and hardest-to-detect incidents a Security Operations Centre (SOC) faces. The 2025 Ponemon Cost of Insider Risks Global Report found that the average cost of an insider-threat incident more than doubled between 2018 and 2024, reaching USD 16.2 million per organisation annually [1]. Verizon's 2025 Data Breach Investigations Report (DBIR) estimates that compromised credentials — a primary insider-threat vector — appeared in 22% of all confirmed breaches [2]. Traditional perimeter controls and signature-based detection are blind to these vectors: an employee who exfiltrates records during authorised working hours, using authorised credentials, triggers no rule-based alert.

User and Entity Behaviour Analytics (UEBA) is positioned, by every major security vendor, as the answer to this gap. Vendors claim that machine-learning behavioural baselines detect the subtle deviations that signal compromise before damage occurs. The UEBA market reached USD 2.39 billion in 2024 and is projected to grow at a compound annual rate exceeding 34% through 2025 [3]. Yet the academic literature on UEBA performance is almost entirely evaluated on one synthetic dataset — the Carnegie Mellon CERT Insider Threat Dataset — and the degree to which those results generalise to live enterprise deployments is rarely examined.

This report argues that UEBA demonstrates credible detection performance in controlled benchmark settings, but that the published evidence does not yet establish equivalent effectiveness in production, because the datasets on which the field evaluates itself are structurally dissimilar to real enterprise telemetry in ways that systematically inflate recall at the cost of operational false-positive rates.

2. Literature Survey and Discussion

2.1 What the papers measured and how

All three peer-reviewed papers surveyed here evaluate UEBA-class anomaly-detection systems on the CERT r4.2 insider-threat dataset, which is the de-facto benchmark in the academic literature. Cain and Beadles (2025) introduce a dual-channel convolutional autoencoder that explicitly separates activity presence from activity magnitude, achieving a window-level precision-recall AUC of 0.71 and a campaign-level AUC of 0.84 across multi-day attack sequences [4]. Bertrand et al. (2022) take an unsupervised Bayesian Gaussian Mixture Model approach — requiring no prior labelling of malicious events — and report 88% recall with a false-positive rate of 6.9%, outperforming several supervised baselines on the same dataset [5]. Cui et al. (2022) propose a fuzzy particle-swarm clustering algorithm and report an F1 score of 0.93 and accuracy of 0.92 [6].

These numbers are, on their face, impressive. A 6.9% false-positive rate sounds modest. In a 1,000-user enterprise generating 10,000 behavioural events per day, however, that translates to 690 daily false alerts — an operationally unsustainable volume for a typical SOC team of three to five analysts [7]. None of the three papers quantify their results in terms of analyst workload or mean-time-to-respond — the metrics an IR team lead would use to evaluate whether a tool is genuinely deployable.

Paper	Method	Dataset	Key Metric	Limitation Acknowledged
Cain & Beadles (2025) [4]	Dual-channel convolutional autoencoder	CERT r4.2	Campaign AUC 0.84	Malicious behaviour artificially sparse in benchmark
Bertrand et al. (2022) [5]	Bayesian Gaussian Mixture Model (unsupervised)	CERT r4.2	Recall 88%, FPR 6.9%	CERT “may not represent real-world insider threats”
Cui et al. (2022) [6]	Fuzzy particle-swarm clustering	CERT r4.2	F1 0.93, Accuracy 0.92	Single benchmark; no adversarial evaluation

Table 1. Summary of three peer-reviewed UEBA empirical studies. All evaluate on CERT r4.2. Own work.

2.2 Where the sources agree

All three papers agree on the core technical premise: behavioural baselining with machine learning detects insider threats that rule-based systems miss, particularly slow-burn campaigns where the attacker’s behaviour diverges from their peer group over days or weeks rather than triggering a single threshold in one session. Cain and Beadles specifically show that campaign-level detection — aggregating anomaly scores across multiple days — improves substantially over window-level detection [4], a finding that aligns with operational intuition

that insider threats rarely announce themselves in a single event. The Frontiers in Big Data comprehensive survey of clustering algorithms for UEBA reaches the same conclusion: unsupervised methods are best positioned to discover anomalies not anticipated at design time [7].

2.3 Where the sources diverge — the dataset gap

The critical disagreement is not between the papers themselves, but between the papers and production reality. Bertrand et al. acknowledge that CERT r4.2 ‘may not be representative of real-world insider threats’ because its synthetic labels are assigned to behavioural sequences generated by researchers simulating malicious activity, not captured from actual compromised users [5]. Cain and Beadles note that malicious behaviour in CERT is ‘highly temporally sparse’ — concentrated in a small number of anomalous days — which makes top-k pooling strategies effective in the dataset but potentially fragile against adversaries who deliberately pace their exfiltration to remain within normal variance [4].

The vendor literature reflects a different, complementary concern. Vectra AI’s 2026 deployment guide notes that UEBA requires a 60–90 day learning period before baselines stabilise, and that ‘static baselines in dynamic environments lead to blind spots or alert fatigue’ [8]. An employee who changes roles, begins remote work, or is promoted during that window will generate elevated anomaly scores for entirely legitimate reasons — exactly the kind of false positive that erodes analyst trust in the system over time. The CERT benchmark, which uses static synthetic users who do not change roles, does not model this problem at all.

The gap compounds further when adversarial adaptation is considered. None of the three academic papers test against an adversary who is aware of the UEBA system and deliberately paces exfiltration to remain within behavioural thresholds — a well-documented evasion strategy in the practitioner literature. A sophisticated insider, or an external attacker who has observed normal patterns over weeks, can reduce their anomaly score by acting incrementally. The academic literature has not yet produced a production-scale adversarial evaluation.

2.4 The privacy dimension

One dimension the academic papers treat as out of scope, but which is operationally central, is employee privacy. UEBA necessarily processes granular behavioural telemetry — file access patterns, application usage, communication metadata — on all users, including those never suspected of wrongdoing. Under EU General Data Protection Regulation (GDPR) Article 22 and Spain’s Ley Orgánica de Protección de Datos (LOPD-GDD), continuous behavioural monitoring of employees requires a documented legal basis, a proportionality assessment, and worker consultation where collective agreements apply. A UEBA deployment that is technically effective but legally unconfigured is a liability risk that can exceed the incident cost it was meant to prevent.

3. Conclusion and Implications

The peer-reviewed evidence reviewed here supports the conclusion that UEBA-class machine-learning systems can detect insider-threat campaigns in controlled benchmark conditions, with precision-recall AUC scores between 0.71 and 0.84 and false-positive rates around 7%. The marketing claim is not wrong — it is incomplete. The gap between CERT r4.2 performance and production efficacy is structurally unavoidable: the benchmark uses synthetic labels, static user roles, and temporally sparse malicious activity that does not reflect the adaptive, low-and-slow behaviour of a motivated insider operating in a live enterprise environment.

For an incident-response team in 2026, the practical implication is direct: a UEBA risk score should be treated as a triage signal — a reason to pull additional data sources and begin an investigation — not as confirmation of compromise. Over-reliance on a UEBA score, particularly in the first 90 days of deployment before baselines have stabilised, risks analyst fatigue from false positives and missed detections from adversarial pacing. The tool is most effective when it is one node in a correlated detection chain — alongside SIEM correlation rules, EDR behavioural alerts, and DLP policy violations — not when it operates as the sole detection surface.

The most consequential next research step would be a production-environment evaluation of a commercial UEBA platform over a 12-month window, measuring analyst-confirmed true positives, false-positive rate, and mean-time-to-triage against a pre-UEBA baseline. No such study currently exists in the open literature — and its absence is itself the clearest evidence that the marketing is ahead of the science.

References

- [1] Ponemon Institute, “Cost of Insider Risks Global Report,” 2025. [Online]. Available: <https://www.proofpoint.com/us/resources/threat-reports/cost-of-insider-risks>. [Accessed: 12 May 2026].
- [2] Verizon, “2025 Data Breach Investigations Report,” Verizon Business, 2025. [Online]. Available: <https://www.verizon.com/business/resources/reports/dbir/>. [Accessed: 12 May 2026].
- [3] The Business Research Company, “User and Entity Behavior Analytics Market Report 2025,” 2025. [Online]. Available: <https://www.thebusinessresearchcompany.com>. [Accessed: 12 May 2026].
- [4] J. Cain and H. Beadles, “Mask-Based Window-Level Insider Threat Detection for Campaign Discovery,” arXiv preprint arXiv:2602.11019, Feb. 2025. [Online]. Available: <https://arxiv.org/abs/2602.11019>. [Accessed: 12 May 2026].
- [5] S. Bertrand et al., “Unsupervised User-Based Insider Threat Detection Using Bayesian Gaussian Mixture Models,” arXiv preprint arXiv:2211.14437, Nov. 2022. [Online]. Available: <https://arxiv.org/abs/2211.14437>. [Accessed: 12 May 2026].
- [6] J. Cui, G. Zhang, Z. Chen, and N. Yu, “Multi-homed abnormal behavior detection algorithm based on fuzzy particle swarm cluster in user and entity behavior analytics,” Scientific Reports, vol. 12, Dec. 2022, doi: 10.1038/s41598-022-26142-w.
- [7] E. Maci et al., “A comprehensive investigation of clustering algorithms for User and Entity Behavior Analytics,” Frontiers in Big Data, vol. 7, Apr. 2024, doi: 10.3389/fdata.2024.1375818.
- [8] Vectra AI, “UEBA Explained: User and Entity Behavior Analytics Guide,” 2026. [Online]. Available: <https://www.vectra.ai/topics/user-and-entity-behavior-analytics-ueba>. [Accessed: 12 May 2026].